dreamDEX Perps — build feedback

48 independently reproducible items (5 major, 43 normal) across the REST API, the WebSocket feed, the docs, the deployed app, the bot kit and the perps contracts on Hideki (chain 50383). Each item is one Markdown file under `feedback/`, one issue per file, in the program's template.

Security items are not in this document or in the repository. They were sent privately to security@dreamdex.io as the rules require.

How each item is reproduced

Most items carry the exact request and response inline: an HTTP status, a response body, a chain read, or a cited source line. Two items ship runnable scripts instead of transcripts. `scripts/perp-oi-cap/` enumerates the 21 perp pools from `PerpPoolFactory.getPerpPools()` on chain 50383 and compares `maxOpenInterest` and `maxPositionSize` against the trader docs table; it needs no wallet and no funds, every call is a read, and its non-zero exit is the finding rather than a crash. `scripts/dry-run-parsers/repro.ts` evaluates the four DRY_RUN parsers the bot-kit ships against the same environment strings and prints which packages disagree, offline, with no chain access.

What is deliberately absent

Items that need funds, a signed message, a live authenticated session or a wallet that can reach testnet are not counted here, because this environment could not execute them. They are tracked separately with the exact check that remains. A finding whose claim did not survive re-reading the shipped source was removed rather than softened; three entries in an earlier draft were written against a paraphrase and were rewritten against the actual lines before this document was generated.

Distribution

- API: 23 items
- docs: 11 items
- contracts: 5 items
- SDK: 5 items
- app: 4 items

Scope

Everything here was observed on testnet against the surfaces the program exposes: the HTTP API on stg and api.testnet, the perps contracts on Hideki 50383, the published docs, the web app, and the public bot-kit repository. No mainnet surface was touched, no third-party account was accessed, and no traffic beyond ordinary read requests and unauthenticated probes was sent. Where a behaviour depends on the contract rather than on the served code, the evidence is an ABI-level or RPC-level read and the item says so, so a reviewer can tell a source-confirmed claim from a behaviour-confirmed one.

Index of items

#	Item	Sev	Area
02	Public storage bucket listing enabled on cdn.dreamdex.io	normal	app
03	CSP report-only header on app.testnet responses discloses internal dev/staging hosts	normal	app
04	Unauthenticated /metrics on api.testnet.dreamdex.io exposes internal route table and traffic stats	normal	API
05	State-changing POST /api/sponsor/warm accepts unauthenticated calls without rate limiting	normal	API
09	Market Data docs promise unknown symbols are silently skipped (empty []), live API returns 400 invalid_param	normal	docs
10	Market Data docs show comma-separated symbols returning [], live API parses both symbols (200 with data)	normal	docs
11	WS operations with missing parameters return a REST-style 404 bad_request envelope instead of the documented invalid_parameters protocol error	normal	API
12	Error Handling table documents error name invalid_interval, live API returns invalid_param for the same case	normal	docs
13	Perps developer page documents chain 50383 while the HTTP API and Contract Addresses page describe a different deployment on 50312; two of the six documented addresses resolve to a different contract there	normal	docs
14	Trader docs list 21 markets as BTC-PERP style names; the REST registry serves BASE:USDso and 404s every -PERP name, including markets whose base ticker it does carry	normal	docs
15	HTTP API base-URL table sends testnet developers to stg.api.dreamdex.io; the perps API host api.testnet.dreamdex.io is undocumented anywhere	normal	docs
16	NUL byte in the URL path returns 400 with empty body and no Error-Name header, violating the documented JSON error contract	normal	API
17	POST /v0/auth/login with a non-JSON Content-Type returns 500 internal_error and leaks a V8 exception string	normal	API
18	Cancel and reduce prepares return calldata for an order id that does not exist	normal	API
19	Leverage endpoint accepts values far above the documented per-market maximum while amount validation enforces the documented minimum	normal	API
20	Nine of twenty-four perps pools have no stop-order registry while the docs advertise TP/SL on every market	normal	contracts
21	Three pools sit outside the insurance-fund tier while the docs present the Insurance Fund as the standard ladder stage	normal	contracts
22	Voucher distributor campaign is over with zero budget and claim() reverts while the docs still promise any address can claim 1,000 USDso	normal	contracts
23	One EOA owns every core perps contract and the shared pool beacon	normal	contracts
24	No perps contract has published source on the explorer	normal	contracts
26	App redirects every visitor to a default market that does not exist in the API registry	normal	app
27	App ships a 10m candle interval option that the candles endpoint and its own OpenAPI spec reject	normal	app
28	Bot kit ships with a default spot symbol that does not exist on the testnet it targets	normal	SDK
29	Same malformed WebSocket frame returns two different validator messages on the two hosts the kit and docs call "testnet"	normal	API
30	One WebSocket feed is published under three different path shapes and the spec's own path variant with a trailing slash 404s	normal	docs
31	Numeric input overflows return 500/503 that leak internal library versions, package names and RPC method names	major	API
32	Order endpoints accept a 5MB JSON body, answer 500 instead of 413, and echo ~10MB back	normal	API
33	Known routes answer unsupported HTTP methods with 404 bad_request instead of 405	normal	API
34	PATCH with no body and no Content-Type reports invalid_amount instead of invalid_request_body	normal	API
35	Duplicate JSON keys in an order request are accepted silently (last-key-wins) and produce calldata	normal	API
36	Query parameter validation is lax: limit accepts non-integer syntax and unknown/negative params are silently ignored	normal	API
37	404 envelopes use an undocumented error name and skip the Error-Name header the docs promise	normal	API

#	Item	Sev	Area
38	Margin deposit ignores the currency parameter entirely while the market vault rejects the same values	normal	API
39	Rate limiting only trips after high-RPS bursts and every 429 advertises Retry-After: 1	normal	API
40	gzip-compressed request body is rejected as invalid JSON instead of 415 Unsupported Media Type	normal	API
41	Stop-order endpoints return 404 on all 24 perp markets, including the 15 that do have a stop-order registry	normal	API
42	WBTC and WETH are listed as both spot and perp under the identical symbol, and every write resolves to the spot market, leaving the perp side unaddressable	normal	API
43	builder/approve encodes any max fee the caller asks for, including values above the pool cap, producing a transaction the pool always reverts	normal	API
44	The spec declares the builder-fee ceilings as unbounded integers while every pool enforces a finite on-chain cap	normal	docs
45	vault/approve answers HTTP 200 with a literal null body for a currency the same endpoint lists as accepted	normal	API
46	The spec's declared production WebSocket pathname 404s on production and staging while testnet accepts it, so spec-generated clients connect only on testnet	major	API
47	The testnet spec advertises nine subscribe channels and production recognises five, so four documented channels answer unknown_channel on mainnet	major	docs
48	Trader docs open-interest cap is 2x or 4x the on-chain cap on 20 of 21 markets	major	docs
49	The bot-kit ships four different DRY_RUN parsers, and the value the docs recommend makes one shipped example trade live	major	SDK
50	example-08's template .env ships DRY_RUN=0, so a copied template is a live configuration and `npm start` reflects no deliberate choice	normal	docs
51	perp-maker's link gate answers `ok: true` when there is no trading key, so it can never fail and the live bot runs on without warning	normal	SDK
52	The margin status reader falls back to "Healthy" for any value outside 0-3, so an unreadable status is reported as the safest one	normal	SDK
53	CHAIN_ID is a free-form override with no range check and no cross-check against the RPC, so a typo signs against one chain while reading another	normal	SDK